Auditoria de Seguranca e Performance - TaskNest

Stack: React 19 + TanStack Router + Fastify + oRPC + Drizzle + PostgreSQL + Better-Auth email/senha. Deploy: Docker Compose. Dados: PII (nome, email, imagem), sensibilidade LGPD.

Data: 10/10/2026. Escopo: apps/server, apps/web, packages/api, packages/auth, packages/db, Docker/nginx. Metodo: leitura de codigo + grep + git ls-files.

1. Resumo Executivo

RISCO GERAL: CRITICO

Severidade	Qtd
Critica	1
Alta	3
Media	3
Baixa	2
Pendente	2

3 problemas mais urgentes:

- **1. invitations.accept sem checar email (IDOR).** Qualquer autenticado com o UUID entra em qualquer projeto. Arquivo: packages/api/src/routers/invitations.ts
- **2. profile.update troca email sem verificacao.** Bypass da tabela verification, emailVerified nao resetado. Arquivo: packages/api/src/routers/profile.ts
- **3. Sem rate-limit e helmet em /api/auth, senha sem politica.** Brute-force liberado. Arquivos: apps/server/src/index.ts + packages/auth/src/index.ts

Achados confirmados no codigo, nao hipoteticos. XSS: dangerouslySetInnerHTML = 0 (React escapa por padrao). Segredos: .env nao versionado (git ls-files NONE_TRACKED). Risco restante: default postgres/postgres e segredo parado em disco.

2. Detalhamento

CRITICA

C-01 - IDOR em accept de convite

Categoria	Seguranca
Localizacao	packages/api/src/routers/invitations.ts, accept: insert projectMember com session.user.id, nunca compara inv.email.
Descricao	Convite amarrado a email, aceite amarrado a quem chama. Com UUID vazavel, invasor entra em projeto alheio e ganha leitura e escrita.
Impacto	CWE-639 / CWE-285. Comprometimento total do projeto invadido.
Esforco	Baixo

Antes

```
        insert projectMember com session.user.id, sem checar inv.email
```

Depois

```
se inv.email difere de session.user.email: FORBIDDEN. Transacao: insert onConflictDoNothing + update accepted
```

ALTA

A-01 - Troca de email sem verificacao

Categoria	Seguranca
Localizacao	packages/api/src/routers/profile.ts, update: email opcional + set direto.
Descricao	Bypassa verification do Better-Auth. emailVerified nao resetado. Colisao unique gera 500 e enumera contas.
Impacto	CWE-640. Account takeover + problema LGPD.
Esforco	Baixo

Depois

```
input apenas com name. Email so via fluxo verificado do Better-Auth
```

A-02 - Sem rate-limit e headers

Categoria	Seguranca
Localizacao	apps/server/src/index.ts: so cors, /api/auth sem throttle. auth: sem minPasswordLength.
Descricao	Login por senha sem barreira a brute-force. Sem HSTS, X-Frame-Options, CSP. Confirmado por ausencia.
Impacto	CWE-307 / CWE-770 / CWE-693.
Esforco	Baixo

Depois

```
helmet + rateLimit max 20 por minuto. Auth: minPasswordLength 12 + requireEmailVerification
```

A-03 - Sem paginacao

Categoria	Performance
Localizacao	tasks.ts list: findMany sem limit/offset + includes. projects.ts list sem limite.
Descricao	Board com N tasks baixa tudo. Payload linear, RAM e egress, Kanban trava.
Impacto	Custo CPU, DB e RAM. Disponibilidade.
Esforco	Medio

Depois

```
limit 1..100 default 50 + offset default 0. findMany com limit e offset
```

MEDIA

M-01 - assigneeId sem validar

Categoria	Seguranca + Performance
Localizacao	tasks.ts create e update: assigneeId inserido direto, sem requireMember.
Descricao	Atribui task a fora do projeto ou inexistente. Inexistente vira FK 500 e enumera IDs.
Impacto	CWE-20 / CWE-639.

Esforco	Baixo

Depois

```
se assigneeId informado: requireMember com assigneeId e projectId antes de inserir
```

M-02 - IN cru + agregacao total

Categoria	Performance
Localizacao	projects.ts list: array JS interpolado em sql. Subquery agrupa task inteira antes de filtrar.
Descricao	Scan e agregacao de todos os projetos e so depois filtra. Piora com escala. IDs vem do banco: corretude e perf, nao SQLi exploravel.
Impacto	Custo O(total tasks) por listagem.
Esforco	Baixo

Depois

```
inArray(task.projectId, projectIds) antes do groupBy. Filtrar antes de agrupar
```

M-03 - Credenciais default

Categoria	Seguranca
Localizacao	docker-compose.yml: POSTGRES_PASSWORD postgres. DATABASE_URL postgres/postgres.
Descricao	.env nao versionado, ok. Risco e reuso em prod e segredo parado em disco.
Impacto	CWE-798.
Esforco	Baixo

BAIXA

B-01 - Log verboso de erro

Categoria	Seguranca
Localizacao	server index.ts: onError com console.error(error) 2x + logger true.
Descricao	Stack e query Drizzle em stdout e logs Docker. Sem PII vista, auxilia fingerprint.
Impacto	CWE-209.
Esforco	Baixo

B-02 - SameSite None global

Categoria	Seguranca
Localizacao	auth/index.ts: sameSite none e secure true sempre.
Descricao	None permite cross-site e amplia CSRF. Em dev HTTP quebra sessao.
Impacto	Baixo, origem unica hoje.
Esforco	Baixo

Pontos positivos confirmados

- Drizzle parametrizado (eq, and, inArray). Zod valida UUIDs, enums e limites.
- Authz por projeto consistente com requireMember. Tags isoladas por usuario.

- FK cascade e set-null + uniques + indices base. Transacoes em create e setTags.
- dockerignore exclui .env. nginx com gzip e assets imutaveis.

3. Longo prazo, priorizadas

- 1. requireEmailVerification + troca de email verificada. Fecha A-01, base LGPD.
- 2. Rate-limit + Helmet + CORS fixo em prod. Fecha A-02.
- 3. Paginacao padrao teto 100 + indice task(projectId, createdAt).
- 4. Check inv.email + teste IDOR com assert. Fecha C-01.
- 5. CI: ultracite check, tsc, gitleaks, Trivy, migrate em prod, nunca push.
- 6. Log so com codigo, auditoria de members e invitations, secret manager, backup PG.

Pendente de verificacao, sem adivinhar: render de comment.body e task.title no frontend; politicas runtime; SSRF (nenhum fetch com input no backend); plano de query sem acesso ao PG prod.